

Common function codes

FC	Name	Direction	Touches
0x01	Read Coils	read	discrete outputs
0x02	Read Discrete Inputs	read	discrete inputs
0x03	Read Holding Registers	read	16-bit holding regs
0x04	Read Input Registers	read	16-bit input regs
0x05	Write Single Coil	write	one discrete output
0x06	Write Single Register	write	one holding reg
0x0F	Write Multiple Coils	write	many discrete outputs
0x10	Write Multiple Registers	write	many holding regs
0x16	Mask Write Register	write	RMW one holding reg
0x17	Read/Write Multiple Regs	write	atomic R+W
0x2B	Encapsulated Interface	meta	vendor / device ID

Exception codes (response with FC | 0x80)

0x01	Illegal function – FC unsupported by slave.
0x02	Illegal data address – register / coil out of range.
0x03	Illegal data value – length or count rejected.
0x04	Slave device failure – internal error.
0x06	Slave busy – retry later.

Modbus TCP frame (request, read holding registers)

MBAP header (incl. Unit, 7 B)					PDU	
Trans ID	Proto ID	Length	Unit	FC	Start	Count
00 01	00 00	00 06	11	03	00 6B	00 03

Reads 3 holding registers starting at 0x006B from unit 0x11.

Address spaces

Coils	FC 1, 5, 15	1-bit read/write outputs.
Discrete inputs	FC 2	1-bit read-only inputs.
Input registers	FC 4	16-bit read-only sensors.
Holding registers	FC 3, 6, 16	16-bit read/write data.

Transports + ports

Modbus TCP – TCP/502, MBAP header (7 B).
Modbus RTU – RS-485, CRC-16 trailer (2 B), no MBAP.
Modbus ASCII – 7-bit serial, LRC trailer; legacy only.
Security – none in the standard. Compensate at the network layer (firewall, allow-list source IPs, segregated zone).

Security policies (SecurityPolicyURI)

Policy	Use
None	no signing, no encryption – pilot / lab only
Basic128Rsa15 (deprecated)	legacy interop only; SHA-1, RSA-PKCS1v1.5
Basic256 (deprecated)	SHA-1, AES-256; avoid for new deployments
Basic256Sha256	modern baseline – SHA-256, AES-256, RSA-2048
Aes128_Sha256_RsaOaep	2018 recommended profile
Aes256_Sha256_RsaPss	2018 strongest binary profile

Message security modes

None	no signing or encryption – only safe with SecurityPolicy = None in a closed test.
Sign	every message MAC-signed; payload visible on the wire (auditing scenarios).
SignAndEncrypt	both – the only acceptable choice in production.

User authentication tokens

Anonymous	default in too many deployments. Disable in production.
UserName	plaintext user + password (encrypted by transport when SignAndEncrypt).
Certificate	X.509 client certificate; preferred for service accounts.
IssuedToken	OAuth-style external IdP (less common in OT).

The four checks before declaring an OPC UA deployment *secure*

1. Security policy is Aes*_Sha256_* (not None, not Basic*).
2. Message security mode is SignAndEncrypt.
3. Anonymous identity is disabled on every endpoint.
4. Server and client trust lists contain only the certificates you put there – and are reviewed on a schedule.

Common gotchas

TCP/4840 default – exposed to a corporate LAN is a finding.
Anonymous endpoint – almost every vendor demo ships with one.
Old server, new client – negotiation falls back to Basic* unless you forbid it explicitly.
Certificate trust – self-signed certs accepted “temporarily” tend to outlive the engineer who accepted them.

Base metric values		
Metric	Meaning	Values
AV Attack Vector	where the attacker must be	N/A/L/P
AC Attack Complexity	conditions outside attacker control	L/H
PR Privileges Required	what creds the attacker needs	N/L/H
UI User Interaction	is a human click needed	N/R
S Scope	does exploit reach other components	U/C
C Confidentiality	impact on confidentiality	N/L/H
I Integrity	impact on integrity	N/L/H
A Availability	impact on availability	N/L/H

Severity bands (base score)		
None	0.0	informational
Low	0.1–3.9	nuisance, narrow exposure
Medium	4.0–6.9	worth a patch window
High	7.0–8.9	schedule a maintenance window
Critical	9.0–10.0	emergency change, board sees this

Environmental modifiers (the OT trick)

CR / IR / AR (Confidentiality / Integrity / Availability Requirement) – raise the weighting of one CIA axis when your asset cares about it more than the average.

MAV / MAC / MPR / MUI / MS / MC / MI / MA – override any base metric with what is true *in your environment* (e.g. change AV:N to MAV:L if the device is on an isolated subnet).

Worked example – PLC on an air-gapped subnet

Base: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8
Env : /MAV:A/MAC:H/CR:L/IR:H/AR:H ≈ 7.5

The vendor’s 9.8 becomes 7.5 once you reflect that the attacker must be on the adjacent network (MAV:A), exploitation needs special conditions (MAC:H), confidentiality is irrelevant (CR:L), and integrity/availability dominate (IR:H/AR:H).

Use in OT

Never quote the base score alone.
Always compute environmental for any patching decision.
Pair with consequence – a high-availability CVSS on a safety-critical PLC is plant-stop territory, not a ticket.
Source – FIRST, *CVSS v3.1 Specification Document*, 2019.

NIS2 timing (Art. 23 incident reporting)

Deadline	Obligation
24 hours	Early warning – detected, suspected malicious cause flagged, cross-border impact stated. Not a full report.
72 hours	Update notice – working hypothesis, initial assessment of severity and impact.
1 month	Final report – detailed description, root cause, mitigation, lessons.

NIS2 scope – who is in?

Essential entities – energy, transport, banking, financial market infrastructure, health, drinking water, waste water, digital infrastructure, ICT service management, public administration, space.

Important entities – postal, waste management, chemicals, food, manufacturing of medical devices / motor vehicles / electrical equipment, digital providers, research.

Size thresholds – generally medium and large entities (≥50 staff or ≥ EUR10 M turnover) unless explicitly named regardless of size.

Transposition deadline – 17 October 2024.

CRA – key dates and duties

Signed – 23 Oct 2024.

Vulnerability + incident reporting – enforceable **11 September 2026**.

Full applicability (most provisions) – **11 December 2027**.

Applies to any *product with digital elements* placed on the EU market – explicitly including connected PLCs, HMIs, gateways. Manufacturer duties:

- 1. Risk-based security across the lifecycle (essential requirements, Annex I).
- 2. Free security updates for at least 5 years (or expected lifetime).
- 3. SBOM, conformity assessment, CE marking.
- 4. Notify exploited vulnerabilities to ENISA within 24/72 hours.

Sanctions ceilings

NIS2 essential entities – up to EUR 10 M or 2 % of global turnover, whichever is higher.

NIS2 important entities – up to EUR 7 M or 1.4 % global turnover.

CRA – up to EUR 15 M or 2.5 % global turnover for essential-requirement breaches.

Personal liability – NIS2 explicitly extends to senior management; member states may bar repeat-offender executives from running an essential entity.

German national context

KRITIS – BSI-Kritisverordnung; the NIS2 transposition law is *NIS2UmsuCG* (supersedes IT-SiG 2.0 for NIS2 duties).

B3S – sector-specific standards under § 8a BSIG; recognised baseline for KRITIS operators.

Reporting portal – BSI *Meldeportal* (meldeportal.bsi.bund.de).